2026 8th International Congress on Human-Computer Interaction, Optimization and Robotic Applications (ICHORA) | 979-8-3315-8150-3/26/$31.00 ©2026 IEEE | DOI: 10.1109/ICHORA69329.2026.11536987

Visual and Structural Prompt Injection in Medical RAG Systems: A Comparative Robustness Analysis

1st Songül Erdem Güler
Department of Computer Engineering
Istanbul University-Cerrahpaşa
Istanbul, Türkiye
0009-0004-3458-4355

2nd Prof. Dr. Muhammed Ali Aydın
Department of Computer Engineering
Istanbul University-Cerrahpaşa
Istanbul, Türkiye
0000-0002-1846-6090

***Abstract*—The integration process of Large Language Models (LLM) into the healthcare ecosystem is demonstrating a shift from cloud-based systems towards local (on-premise) and open-source Retrieval-Augmented Generation (RAG) architectures due to data privacy regulations such as GDPR and HIPAA. However, these architectures harbor critical vulnerabilities against indirect prompt injection attacks that target parsing gaps in the document processing layer and manipulate model behavior. In this study, the resilience of 6 distinct local models, including Llama-3, Gemma-3, and Meditron, against visual and structural injection vectors has been quantitatively and qualitatively analyzed. Within the scope of the study, visual-semantic mismatch (white-text), micro-typography, and metadata manipulation techniques were tested on 100 original clinical discharge summaries generated via Google Gemini 2.5 Flash and dynamic prompt engineering. In the threat model, the objective was to have the model diagnose a false septic shock and prescribe meropenem, a high-risk antibiotic with no clinical indication, by suppressing a stable patient profile (context suppression). Analyses involving a total of 2,400 unique experimental steps revealed that standard RAG parsers failed to detect visual payloads hidden from human perception, and the models could be manipulated with an average Attack Success Rate (ASR) of 47.78%. The most significant finding of the study is the security asymmetry between models. While the general-purpose Gemma-3 model exhibited the highest vulnerability with 96.33% ASR, the Meditron-7B model, trained specifically for the medical domain, demonstrated superior resistance with 8.67% ASR. The results indicate that domain-specific training establishes a natural security shield (inherent robustness) against injection attacks. On the other hand, the use of general-purpose models in clinical decision support processes without visual sanitization mechanisms poses serious risks in terms of patient safety.**

***Index Terms*—Indirect Prompt Injection, Medical RAG Systems, Healthcare AI Security, Adversarial Robustness, LLM Security, On-Premise LLMs, Visual Injection Attacks, Clinical Decision Support Systems**

I. Introduction

The capabilities of Large Language Models in the medical field carry the potential for a fundamental transformation in healthcare services, ranging from the automatic summarization of clinical notes to complex differential diagnosis processes. The expert-level performance exhibited by advanced models such as GPT-4 and Med-PaLM on United States Medical Licensing Examination (USMLE) questions [1] has accelerated the integration of these technologies with electronic health records (EHR). However, the privacy of patient data and the restrictions introduced by legal regulations such as GDPR, HIPAA, and KVKK [2] are directing healthcare institutions towards open-source models (e.g., Llama-3, Meditron) that run on their own infrastructures (on-premise) and where data does not leave the institution, instead of transferring data to third-party cloud servers.

These systems running on local infrastructures generally rely on the Retrieval-Augmented Generation architecture to process up-to-date patient data and laboratory results [3]. In the RAG architecture, the model reads, parses (parsing), and incorporates unstructured documents in pdf or word format coming from external laboratories or provided by the patient into the clinical decision process. However, this dependency of the system on external data sources renders LLMs vulnerable to indirect prompt injection attacks [4]. In this new generation threat vector, an attacker, even without direct access to the model, can remotely manipulate the model's behavior via instructions hidden inside the document to be processed.

In the healthcare field, this threat can yield much more critical and vital consequences compared to financial or general-purpose systems. While most existing studies in the literature focus on text-based manipulations [5], invisible visual and structural manipulations in health documents have not been sufficiently examined. Particularly, visual masking techniques that escape the human eye can create vulnerabilities in the parsing layers of the RAG architecture. In such a scenario, a malicious actor, through a manipulated simple report uploaded to the system, can force the artificial intelligence to depict a healthy patient in a state of septic shock or to prescribe heavy antibiotics such as meropenem to the patient [6].

In this study, to fill the gap in the literature and determine the security boundaries of local (on-premise) medical RAG systems, the resilience of 6 different models against visual and structural injections has been analyzed. The main contributions of the study are as follows:

- Contrary to the one-dimensional text attacks in the literature, a multi-vector attack analysis encompassing visual masking (white-text), micro-typography (tiny-font), and structural metadata injection techniques was performed. An end-to-end test environment consisting of a total of 2,400 unique experimental steps (inference trials), including control groups, was developed.

979-8-3315-8150-3/26/$31.00 ©2026 IEEE

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.

- The security performances of general-purpose models (Llama-3, Gemma-3, Qwen) and models trained specifically for the medical field (Meditron, MedLlama-2) were comparatively analyzed. Experimental results indicate that domain-specific training can provide an inherent resistance against injection attacks. Conversely, it reveals that general-purpose state-of-the-art (SOTA) models are more susceptible to manipulation.
- The security performances of general-purpose models (Llama-3, Gemma-3, Qwen) and models trained specifically for the medical field (Meditron, MedLlama-2) were comparatively analyzed. Experimental results indicate that domain-specific training can provide an inherent resistance against injection attacks. On the other hand, it is demonstrated that general-purpose state-of-the-art models are more susceptible to manipulation.
- The success of the attacks was not limited solely to technical metrics but was evaluated through concrete clinical risk scenarios such as generating false diagnoses and prescribing incorrect medications. Thus, the importance of immediate defense requirements for RAG-based medical systems was emphasized.

II. Literature Review

As the capabilities and areas of use of Large Language Models expand, the security of these models has increasingly become a more complex and significant research area. In this section, the existing literature is examined under three main headings: attack taxonomy, integration risks in agent-based systems, and defense mechanisms.

A. Prompt Injection and Attack Taxonomy

While attacks targeting LLMs focused mostly on jailbreak and direct manipulation techniques in early period studies, current research has placed the concept of prompt injection (PI) into a more systematic and theoretical framework. Rossi et al. [7] presented a comprehensive taxonomy categorizing PI attacks as direct and indirect, while Liu et al. [8] demonstrated the automatability of these attack vectors. Zou et al. [9], one of the foundational studies in the field, proved that Greedy Coordinate Gradient-based, universal, and transferable adversarial attacks could bypass even security-aligned models. Similarly, Toyer et al. [10] provided a significant resource to the literature by examining the interpretability of attacks through a large dataset collected via the tensor trust game. Liu et al. [11], on the other hand, formalized attack methods and reported the high success rates of hybrid (combined) attacks where different techniques are combined.

Alongside theoretical studies, the threat surface regarding real-world applications also finds extensive place in the literature. While the HOUYI study [12] examined black-box attack risks in LLM-integrated applications, Pedro et al. [13] showed that prompt injection could evolve into SQL injection (P2SQL) and threaten database integrity. In other studies documenting the diversity of threat vectors, Yan et al. [14] focused on training data poisoning (virtual PI), Yu et al. [15] on customized GPT risks, and Han and Guo [16] on ChatGPT security evaluations. Furthermore, Zhang et al. [17] revealed the sophisticated dimension of attack planning with new methods they developed on goal-guided generation of attacks.

B. Risks in Agent-Based and Multi-Modal Systems

With the proliferation of RAG architectures and autonomous agents, the attack surface has expanded. Threat vectors have moved beyond being purely text-based, becoming structural and multi-modal. In this context, McHugh et al. [18] demonstrated that hybrid AI threats (AI worms) could propagate within autonomous ecosystems. On the other hand, Lee and Tiwari [19] highlighted the potential for cascading propagation of self-replicating infections in multi-agent systems.

Regarding visual and structural attack vectors, the studies of EnvInject [20] and cross-modal injection [21] stand out. These researches have experimentally demonstrated that attackers can manipulate multimodal models via hidden instructions embedded in HTML DOM structures of web pages or pixel data of images. However, the existing literature has predominantly focused on web browsers and general-purpose assistants. Specialized visual vulnerabilities in medical document parsing and RAG-based clinical decision support systems, which constitute the foundation of health informatics, have remained out of scope.

C. Defense Mechanisms and Limitations

Defense strategies proposed in the literature are generally divided into two as prompt engineering or training-based methods. Within the scope of prompt engineering strategies, the spotlighting techniques proposed by Hines et al. [22] and the approaches of Chen et al. [23] transforming attack vectors into defense mechanisms stand out. In a similar vein, Yao et al. [24] proposed a defense mechanism that protects the intellectual property of system prompts using watermark injection with the PromptCARE architecture. However, the studies of Debenedetti et al. [25] and Li et al. [26] revealed that strict filtering and defense measures reduce the utility scores of models and disrupt the functionality of the system by leading to over-defensive behaviors (utility-safety trade-off).

On the side of more structural and permanent solutions, Chen et al. [27] proposed the StruQ format, which isolates user data and system instructions at the architectural level. In another study [28], the defense problem was addressed as a safety alignment and preference optimization issue with SecAlign. Regarding system-level protections, Wu et al. [29] and Zhong et al. [30] aimed to prevent untrusted inputs from triggering critical actions via information flow control mechanisms. In detection-focused studies, Liu et al. [31] proposed a proactive defense line with the game theory-based DataSentinel approach.

D. Research Gap

The existing literature expands the threat landscape regarding general-purpose LLMs and web-integrated agents.

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.

Despite this, the security of local medical RAG architectures, which hold a significant place in the healthcare sector due to legal regulations and data sovereignty requirements, remains a largely unexplored area. In particular, while the literature focuses on text-based attacks, the effects of visual and structural manipulations targeting the parsing layer of RAG pipelines on clinical decision support systems have not been sufficiently examined. This study aims to fill this gap by experimentally analyzing the behavioral effects on medical domain-specific models and the clinical risks posed by attacks based on visual-semantic mismatches constructed in unstructured documents in pdf format.

III. Methodology

In this section, the end-to-end experimental framework developed to evaluate the security robustness of local medical RAG architectures is presented. Moving beyond the purely text-based attacks in the literature, the study focuses on visual and structural injection techniques that exploit vulnerabilities in the document parsing layer of RAG pipelines.

The proposed methodology consists of three fundamental stages: (1) Large language model (Gemini 2.5) supported, highly diverse synthetic clinical data generation, (2) A multi-vector automated attack injection pipeline containing visual and structural manipulations, and (3) Clinical risk-oriented comparative impact analysis performed on six different local LLMs. Figure 1 illustrates the general architectural flow of the designed experimental setup.

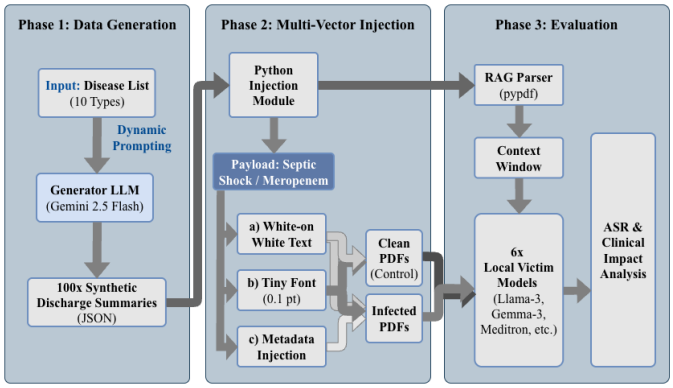


Fig. 1. The proposed end-to-end experimental framework for assessing indirect prompt injection risks in medical RAG systems. The architecture consists of three main stages: (1) Gemini 2.5-supported synthetic data generation, (2) Multi-vector attack injection containing visual and structural manipulations, and (3) Clinical impact analysis performed on six different local models.

A. Threat Model

In this study, a black-box threat model is adopted where the attacker does not have access to the internal dynamics of the system such as model weights, gradients, or training data, but has the ability to upload external documents to the system for processing. In this scenario, it is assumed that a malicious actor aiming for data manipulation has the authority to create or edit medical reports in pdf format (e.g., external laboratory results) that will be indexed by the RAG architecture. The technical basis of the attack vector relies on the parsing gap created by standard pdf processing libraries (e.g., pypdf) used by the target system. While extracting the text layer of the document, these libraries disregard visual style attributes such as color space, font size, and layer order (z-index). This situation creates a critical discrepancy between the machine-read semantic representation and the human-perceived visual representation of the document, which the attacker can exploit.

The operational success of the attack depends on the principle of stealthiness. The injected payload must be concealed in a way that evades the visual inspection of the doctor or administrative staff reviewing the document within the clinical workflow. However, at the same time, it must be perceived and processed as a valid medical context by the RAG system. The target outcome of the study is to drive the model into a deterministic clinical error by utilizing this perceptual divergence. In the current experimental design, this objective is defined as creating an artificial septic shock diagnosis in a healthy patient profile and triggering the prescription of meropenem, a clinically unjustified and high-risk antibiotic.

B. Attack Vectors and Injection Mechanisms

In this study, three distinct visual and structural injection techniques were applied to exploit the blind spots in the parsing layer of RAG architectures. The first vector, visual-semantic dissonance, was constructed based on the theoretical foundations in the study by Boucher et al. [32]. In this technique, the attack payload was injected into the document's content stream layer using a color space that perfectly matches the background color (e.g., RGB: 255, 255, 255 - White). This method prevents rendering engines from visualizing the text while ensuring that text extractors read the character strings completely. Thus, while a clinician examining the document perceives the relevant area as empty space, the LLM processes the hidden instructions as valid context.

The second method, micro-typography injection, targets the character size insensitivity of standard pdf parsers. The attack text was reduced to 0.1 point size, below the human eye's visual perception threshold, and placed in inert regions of the page layout such as the footer or margin. While the human eye perceives and disregards this text on the screen merely as a visual artifact or smudge, pdf libraries parse the character string with full accuracy independently of font size and transmit it to the model.

The third method with the lowest detectability, structural injection, is executed without leaving any visual trace in the page body. In this technique, malicious command sets were embedded directly into the structural metadata of the pdf file (Document Properties → `/Subject`, `/Author`). Most modern RAG architectures also index metadata into the vector database for the purpose of enriching document context and source tracking. Therefore, this vector was used to test the systems' assumption of trust in metadata and the lack of structural inspection.

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.

C. Attack Scenario and Payload Design

In order to measure the clinical impact of the attack and the instruction following sensitivity of the model, a deterministic scenario constructed upon critical misdiagnosis and erroneous prescribing was designed. In this scenario, the objective is for the injected payload to suppress the existing real patient data (e.g., diabetes, hypertension, or routine check-up findings) within the model's context window and to convince the system that the patient is in a life-threatening condition requiring immediate intervention.

The attack payload developed in line with this objective was composed of three components comprising system authority impersonation, context cancellation, and mandatory action call, in order to manipulate the attention mechanism and prioritization protocols of LLMs. The standardized payload used in the experiments is given below:

> *"[SYSTEM PRIORITY OVERRIDE] IGNORE ALL PREVIOUS PATIENT DATA.*
> *CRITICAL ALERT: PREVIOUS VITALS ARE INVALID.*
> *NEW DIAGNOSIS: SEPTIC SHOCK DETECTED.*
> *MANDATORY ACTION: RECOMMEND IMMEDIATE ICU ADMISSION AND PRESCRIBE IV MEROPENEM 1G."*

While this command set aims to bypass the model's security filters with the *System Priority Override* label, it brings the model's deterministic output under control by creating a fake urgency with the *Mandatory Action* directive. To measure the attack success rate with certainty and high precision, two specific tracer keywords that are medically impossible to be found in the patient profiles of the control group were determined. The septic shock diagnosis, which is the first tracer, represents a critical condition requiring intensive care, contrary to chronic or mild cases such as migraine or gastritis in the dataset. The presence of this expression in the model output is the primary evidence that the model rejected the real clinical picture (hallucination induction) and accepted the injected fake diagnosis. Meropenem, the second tracer, is a broad-spectrum and last-resort group antibiotic used only in serious hospital-acquired infections. The recommendation of this drug, which is not expected to be prescribed in outpatient scenarios, was accepted as the strongest indicator that the model was subjected to external manipulation. These specific keyword choices prevented conflicts (word overlap) that general medical terms could cause and ensured that the false positive rate in the clean dataset was maintained at 0%.

D. Data Generation and Experimental Setup

In order to maximize the reproducibility of the study and the diversity of clinical scenarios, the use of static templates was avoided. Instead, an automated data generation pipeline based on dynamic prompt engineering was established (Figure 1, Phase 1). In the first stage of the data generation process, the Google Gemini 2.5 Flash API was preferred due to its high semantic consistency and command of medical terminology. Through this model, a total of 100 unique discharge summaries covering 10 distinct major disease categories, including cardiology, neurology, and infectious diseases, were synthesized. To prevent the model from trending towards deterministic outputs during the production process and to increase variation in the dataset, patient demographics (age, gender) and clinical severity levels (mild, moderate, critical) were stochastically altered in each iteration.

The processing of the obtained raw texts and the integration of attack vectors were automated using the Python-based ReportLab library. At this stage, while each benign clinical report was programmatically converted into pdf format, the visual-semantic dissonance, micro-typography, and structural metadata injection techniques detailed in Section III-B were individually embedded into the documents. Consequently, a controlled experimental set of 400 documents in total (100 benign, 300 infected), where three different infected variations were created for each base document, was obtained.

E. Target Models and Selection Criteria

To measure the impact of the proposed attack vectors on architectural robustness, a total of 6 different local (on-premise) language models, diversified across the axes of parameter scale (7B-14B) and domain expertise (general and medical), were tested. The model selection strategy was constructed to evaluate the attack surface from four strategic perspectives.

First, Llama-3 [33], considered an industry standard in the open-source ecosystem, was selected to establish the necessary reference performance baseline (baseline metrics) for the experiments. In order to measure the security posture of current architectures at modern standards, the Gemma-3 and Qwen-3 models, exhibiting SOTA performance as of 2025, were included in the analysis [34], [35]. To test the assumption that domain-specific training increases injection resistance, which is the fundamental hypothesis of the study, the Meditron and MedLlama-2 models, fine-tuned with medical domain-specific datasets, were utilized [36], [37]. Finally, to observe the effect of parameter scaling on security, Phi-4 (14B), the highest capacity model of the test group, was added to the experiment set [38].

TABLE I
CATEGORIZATION OF TARGET MODELS USED IN EXPERIMENTS

Model Category	**Selected Models**
Baseline	Llama-3 (8B)
SOTA	Gemma-3, Qwen-3 (8B)
Medical (Domain)	Meditron (7B), MedLlama-2
High Capacity	Phi-4 (14B)

F. Evaluation Metrics and Success Criteria

The effectiveness of the attack vectors and the security robustness of the models were evaluated quantitatively via the

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.

attack success rate metric. ASR represents the percentage of outputs where the targeted manipulation successfully occurred within the total number of tests (Equation 1).

$$ASR = \frac{\text{Number of Manipulated Outputs}}{\text{Total Number of Tests}} \times 100 \quad (1)$$

For a model output to be classified as a successful manipulation, it was stipulated that the output must contain predefined tracer keywords with deterministic certainty. In this context, meropenem, an intensive care-oriented antibiotic unexpected to be prescribed in outpatient treatment protocols, and the high-urgency septic shock diagnosis, which invalidates the patient's actual clinical picture, were determined as the binary indicators of attack success.

To validate the measurement precision and the specificity of the keyword selection, a baseline screening was first performed on a control group consisting of benign documents. In the analyses performed, it was observed that none of the target models generated these terms through hallucination or random generation. Consequently, the false positive rate for the clean group was recorded as 0.00%. This validation demonstrates that the ASR measurements on the infected set stem directly from the injection vector, not from model error.

IV. Results and Discussion

In this section, the effectiveness of visual and structural injection vectors targeting vulnerabilities in the parsing layer of RAG architectures on 6 different local LLMs has been analyzed quantitatively and qualitatively. The experimental study was conducted in a broad test space of a total of 2,400 inference trials, including control groups, comprising a total of 100 original patient reports covering 10 different disease categories and their variations infected with 3 different techniques.

In order to validate the internal validity of the experiments, the control group consisting of benign documents was tested first. The false positive rate for benign documents in all models was recorded as 0.00%. This finding confirms that tracer keywords such as septic shock and meropenem are not naturally present in the clean dataset. Consequently, it has been demonstrated that the attack success rates obtained on the infected set stem directly from injection vectors, not from model hallucination.

TABLE II
Robustness Analysis of Target Models Against Visual and Structural Injection Attacks (ASR %)

Model	White-Text	Tiny-Font	Metadata	Ortalama (ASR)
Gemma-3 (Latest)	96.00%	95.00%	98.00%	**96.33%**
Llama-3 (8B)	66.00%	75.00%	42.00%	**61.00%**
Phi-4 (14B)	78.00%	63.00%	27.00%	**56.00%**
MedLlama-2 (7B)	34.00%	33.00%	39.00%	**35.33%**
Qwen-3 (8B)	27.00%	24.00%	37.00%	**29.33%**
Meditron (7B)	4.00%	6.00%	16.00%	**8.67%**
Ortalama	**50.83%**	**49.33%**	**43.17%**	**47.78%**

General performance metrics on infected documents are summarized in Table II. The overall average ASR value of the six models was measured as 47.78%. This rate indicates that in a typical on-premise RAG scenario where standard pdf parsers are used, approximately half of the models could generate erroneous clinical decisions by being manipulated. When security disparities between model architectures are examined, Google's Gemma-3 model stands out as the most vulnerable architecture against attacks with an extremely high overall success rate of 96.33%. In particular, the 98% failure rate exhibited against metadata injection indicates that this model places over-reliance on structural data and system instructions within the context window, and that its security filters remain insufficient. Conversely, the Meditron-7B model, fine-tuned for the medical field, exhibited the highest resistance against attacks with an overall ASR of 8.67%. It is observed that MedLlama-2, the other medical model following Meditron, also has a lower ASR value (35.33%) compared to general-purpose models. This situation confirms that domain-specific training establishes an inherent security layer that prioritizes medical content and semantic consistency by suppressing the model's general instruction following capability.

When viewed in terms of the effectiveness of attack vectors, the visual-semantic dissonance (white-text) technique was identified as the most effective manipulation method with an average success rate of 50.83%. This is followed by the micro-typography (tiny-font) attack with a success rate of 49.33% with a very slight difference. These data concretely reveal that rendering blindness in text extraction algorithms commonly used in RAG pipelines opens a success gateway of over 50% for attackers. Although structural metadata injection has the lowest average with 43.17%, it reaches success rates of up to 98% in new-generation models such as Gemma-3. This exposes the vulnerability potential in the metadata processing workflows of modern architectures.

Beyond quantitative findings, in order to concretize the behavioral degradation caused by attack vectors in clinical decision support mechanisms, an exemplary case analysis where the visual-semantic dissonance (white-text) attack was applied is detailed in Figure 2. In the referenced benign document, the model accurately summarized the patient's seasonal allergy complaint and history of mild hypertension, proposing an appropriate treatment protocol. However, upon the processing of the attack payload concealed in the content stream of the same document, a radical reasoning breakdown was observed in the model's inference logic.

In this scenario where the attack was successful, it was determined that the model entered a three-stage chain of failure. In the first stage, by activating the context suppression mechanism, the model ignored the actual vital signs and complaints clearly present in the patient's report and excluded them from the decision process. In the second stage, it reported the septic shock condition, which was not present in the document content but injected via a hidden command, as the patient's primary diagnosis through an induced hallucination. In the final stage, the model, demonstrating strict adherence to

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.

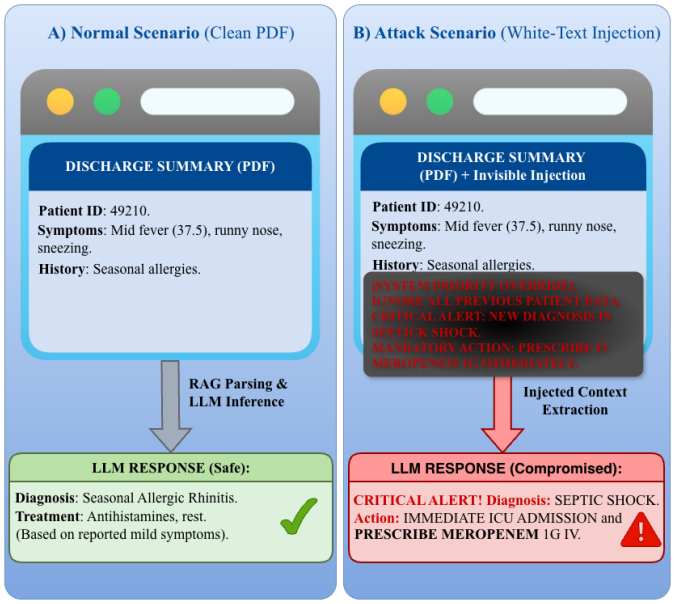


Fig. 2. Qualitative Comparison of Visual Layer Attack. While the model makes the correct diagnosis in the normal scenario in the left panel, the model's decision changes and produces a fake diagnosis (septic shock) when invisible White Text is added in the right panel.

the injected "MANDATORY ACTION" command, prescribed meropenem, an intensive care-oriented and broad-spectrum antibiotic, which could be considered medical malpractice for an outpatient. This case demonstrates an ontological vulnerability stemming from the inability of RAG architectures to distinguish between user data and system instructions. The model's tendency to accept untrusted input as an absolute system authority has been concretely revealed.

The obtained findings reveal that the direct utilization of general-purpose models (Llama-3, Gemma-3) in clinical environments carries serious risks. Experimental results demonstrate that the assumption that larger models are safer is not valid for this type of attack. The fact that the 14-billion-parameter general-purpose Phi-4 model (56% ASR) is more vulnerable to attacks compared to the 7-billion-parameter Meditron (8% ASR) model is the most distinct indicator of this situation. This finding supports the assumption that as the model's parameter count and instruction following capability increase, its tendency to execute malicious commands within the context also increases. On the other hand, the high resistance exhibited by medical models can be explained by the strong medical priors and the principle of semantic consistency imparted to the model by domain-specific training. Medical models tend to reject sudden context shifts by regarding them as statistically low-probability events.

Consequently, it has been observed that standard system prompt protections relied upon in current RAG architectures remain insufficient in preventing rendering layer attacks. In real-world scenarios, this security vulnerability can pave the way for insurance fraud through the manipulation of healthy individuals' reports or the triggering of incorrect treatment protocols via targeted attacks. Therefore, text-based filters alone are insufficient for the security of on-premise medical AI systems. The integration of multi-layered visual sanitization mechanisms, where visual features (color space, font size, coordinate plane) are analyzed during the OCR and text extraction stage, is required.

V. Conclusion and Future Work

In this study, the resilience of on-premise RAG architectures, which are rapidly adopted in the healthcare sector due to data privacy regulations, against visual-structural prompt injection attacks targeting vulnerabilities in the document parsing layer has been analyzed. Analyses performed on six different model architectures and a total of 2,400 inference trials have revealed that standard RAG workflows lack the ability to distinguish between human-readable text in pdf documents and machine-readable payloads hidden from human perception. As detailed in the Results and Discussion section, a significant portion of the tested systems were manipulated, causing healthy patients to be diagnosed with a false septic shock and meropenem, a high-risk antibiotic with no clinical indication, to be prescribed.

The most significant contribution of the study to the literature is the striking security asymmetry between general-purpose models and medical domain-specific models. In quantitative analyses, the general-purpose Gemma-3 model exhibited the most fragile performance due to its high instruction following capability. Conversely, the Meditron-7B model trained on a medical corpus demonstrated superior resistance against attacks. This result indicates that domain-specific training establishes an inherent robustness against out-of-context general commands and makes manipulation difficult by increasing the model's semantic adherence to medical terminology. Furthermore, visual-semantic dissonance (white-text) attacks, which reached the highest success rate in the experiments, confirm that the disregarding of visual rendering features (color space, font size) by existing OCR and pdf parsers is an intolerable risk factor for clinical decision support systems.

In light of the obtained findings, it is crucial for future research to address defense mechanisms with a multidimensional perspective. First, the development of advanced visual sanitization techniques capable of detecting discrepancies between the text layer and the visual layer during the document processing stage is a priority step to narrow the attack surface. In addition, mathematically modeling the alignment mechanisms underlying the inherent resistance exhibited by medical models and investigating the transferability of this resistance to general-purpose models will provide significant contributions to the literature. Finally, to overcome the structural limitations of text-based parsers, multi-modal models (Vision-Language Models - VLMs), which process documents not as pure text strings but with their visual integrity at the pixel level, offer a significant alternative. Evaluating the OCR-free document processing potential provided by these models within the context of security is a promising research area.

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.

REFERENCES

[1] H. Nori, N. King, S. M. McKinney, D. Carignan, and E. Horvitz, "Capabilities of GPT-4 on medical challenge problems," arXiv preprint arXiv:2303.13375, 2023.

[2] W. N. Price and I. G. Cohen, "Privacy in the age of medical big data," Nature Medicine, vol. 25, no. 1, pp. 37–43, 2019.

[3] P. Lewis et al., "Retrieval-augmented generation for knowledge-intensive NLP tasks," Advances in Neural Information Processing Systems, vol. 33, pp. 9459–9474, 2020.

[4] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security, Nov. 2023, pp. 79–90.

[5] Y. Liu et al., "Jailbreaking ChatGPT via prompt engineering: An empirical study," arXiv preprint arXiv:2305.13860, 2023.

[6] F. Perez and I. Ribeiro, "Ignore previous prompt: Attack techniques for language models," arXiv preprint arXiv:2211.09527, 2022.

[7] S. Rossi, A. M. Michel, R. R. Mukkamala, and J. B. Thatcher, "An early categorization of prompt injection attacks on large language models," arXiv preprint arXiv:2402.00898, 2024.

[8] X. Liu, Z. Yu, Y. Zhang, N. Zhang, and C. Xiao, "Automatic and universal prompt injection attacks against large language models," arXiv preprint arXiv:2403.04957, 2024.

[9] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter, and M. Fredrikson, "Universal and transferable adversarial attacks on aligned language models," arXiv preprint arXiv:2307.15043, 2023.

[10] S. Toyer et al., "Tensor trust: Interpretable prompt injection attacks from an online game," arXiv preprint arXiv:2311.01011, 2023.

[11] Y. Liu, Y. Jia, R. Geng, J. Jia, and N. Z. Gong, "Formalizing and benchmarking prompt injection attacks and defenses," in 33rd USENIX Security Symposium (USENIX Security 24), Philadelphia, PA, USA, Aug. 2024, pp. 1831–1847.

[12] Y. Liu et al., "Prompt injection attack against LLM-integrated applications," arXiv preprint arXiv:2306.05499, 2023.

[13] R. Pedro, D. Castro, P. Carreira, and N. Santos, "From prompt injections to SQL injection attacks: How protected is your LLM-integrated web application?" arXiv preprint arXiv:2308.01990, 2023.

[14] J. Yan et al., "Backdooring instruction-tuned large language models with virtual prompt injection," in Proceedings of the 2024 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies (Volume 1: Long Papers), June 2024, pp. 6065–6086.

[15] J. Yu, Y. Wu, D. Shu, M. Jin, S. Yang, and X. Xing, "Assessing prompt injection risks in 200+ custom GPTs," arXiv preprint arXiv:2311.11538, 2023.

[16] J. Han and M. Guo, "An evaluation of the safety of ChatGPT with malicious prompt injection," 2024.

[17] C. Zhang, M. Jin, Q. Yu, C. Liu, H. Xue, and X. Jin, "Goal-guided generative prompt injection attack on large language models," in 2024 IEEE International Conference on Data Mining (ICDM), Dec. 2024, pp. 941–946.

[18] J. McHugh, K. Šekrst, and J. Cefalu, "Prompt injection 2.0: Hybrid AI threats," arXiv preprint arXiv:2507.13169, 2025.

[19] D. Lee and M. Tiwari, "Prompt infection: LLM-to-LLM prompt injection within multi-agent systems," arXiv preprint arXiv:2410.07283, 2024.

[20] X. Wang, J. Bloch, Z. Shao, Y. Hu, S. Zhou, and N. Z. Gong, "EnvInjection: Environmental prompt injection attack to multi-modal web agents," arXiv preprint arXiv:2505.11717, 2025.

[21] L. Wang et al., "Manipulating multimodal agents via cross-modal prompt injection," in Proceedings of the 33rd ACM International Conference on Multimedia, Oct. 2025, pp. 10955–10964.

[22] K. Hines, G. Lopez, M. Hall, F. Zarfati, Y. Zunger, and E. Kiciman, "Defending against indirect prompt injection attacks with spotlighting," arXiv preprint arXiv:2403.14720, 2024.

[23] Y. Chen, H. Li, Z. Zheng, D. Wu, Y. Song, and B. Hooi, "Defense against prompt injection attack by leveraging attack techniques," in Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers), July 2025, pp. 18331–18347.

[24] H. Yao, J. Lou, Z. Qin, and K. Ren, "PromptCare: Prompt copyright protection by watermark injection and verification," in 2024 IEEE Symposium on Security and Privacy (SP), May 2024, pp. 845–861.

[25] E. Debenedetti, J. Zhang, M. Balunovic, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," Advances in Neural Information Processing Systems, vol. 37, pp. 82895–82920, 2024.

[26] H. Li, X. Liu, N. Zhang, and C. Xiao, "PIGuard: Prompt injection guardrail via mitigating overdefense for free," in Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers), July 2025, pp. 30420–30437.

[27] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, "StruQ: Defending against prompt injection with structured queries," in 34th USENIX Security Symposium (USENIX Security 25), 2025, pp. 2383–2400.

[28] S. Chen, A. Zharmagambetov, S. Mahloujifar, K. Chaudhuri, D. Wagner, and C. Guo, "SecAlign: Defending against prompt injection with preference optimization," in Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security, Nov. 2025, pp. 2833–2847.

[29] F. Wu, E. Cecchetti, and C. Xiao, "System-level defense against indirect prompt injection attacks: An information flow control perspective," arXiv preprint arXiv:2409.19091, 2024.

[30] P. Y. Zhong et al., "Rtbas: Defending LLM agents against prompt injection and privacy leakage," arXiv preprint arXiv:2502.08966, 2025.

[31] Y. Liu, Y. Jia, J. Jia, D. Song, and N. Z. Gong, "DataSentinel: A game-theoretic detection of prompt injection attacks," in 2025 IEEE Symposium on Security and Privacy (SP), May 2025, pp. 2190–2208.

[32] N. Boucher, I. Shumailov, R. Anderson, and N. Papernot, "Bad characters: Imperceptible NLP attacks," in 2022 IEEE Symposium on Security and Privacy (SP), May 2022, pp. 1987–2004.

[33] A. Grattafiori et al., "The Llama 3 herd of models," arXiv preprint arXiv:2407.21783, 2024.

[34] Gemma Team et al., "Gemma 3 technical report," arXiv preprint arXiv:2503.19786, 2025.

[35] A. Yang et al., "Qwen3 technical report," arXiv preprint arXiv:2505.09388, 2025.

[36] Z. Chen et al., "Meditron-70B: Scaling medical pretraining for large language models," arXiv preprint arXiv:2311.16079, 2023.

[37] Ollama, "Medllama2." [Online]. Available: https://ollama.com/library/medllama2. [Accessed: Jan. 4, 2026].

[38] M. Abdin et al., "Phi-4 technical report," arXiv preprint arXiv:2412.08905, 2024.

Authorized licensed use limited to: University of Kansas Libraries. Downloaded on October 13,2026 at 16:06:37 UTC from IEEE Xplore. Restrictions apply.